CARLOS GABRIEL GOMES LUZ

APPLICATION SECURITY (APPSEC) | DEVSECOPS | ENGENHARIA DE SOFTWARE

São Paulo, SP | +55 (11) 96762-2665 | carlosgabriel.contato2007@gmail.com
linkedin.com/in/dev-carlosgabriel | github.com/CarlossgLuz | carlosg.com.br

RESUMO PROFISSIONAL

Analista de Desenvolvimento de Sistemas Jr. com experiência prática em segurança de aplicações (AppSec), ASPM e DevSecOps, em trajetória de especialização na área. Atuação na evolução do XGuardian, com participação em iniciativas de gestão de vulnerabilidades, segurança da cadeia de software, controles de acesso e automação. Base sólida em desenvolvimento e operações, permitindo conectar necessidades de segurança ao código, às integrações e ao ciclo de vida das aplicações. Fluxo de trabalho integrado a IA generativa, modelos decisores, agentes e integrações por APIs e MCP para apoiar investigações técnicas, testes de qualidade e melhoria de processos.

EXPERIÊNCIA PROFISSIONAL

Xmart Solutions | Santo André, SP

Analista de Desenvolvimento de Sistemas Jr. | jun/2026 – atual

- Evolução do XGuardian, plataforma SaaS de AppSec e ASPM, com melhorias em funcionalidades e relatórios de SAST, SCA, DAST, Container Security e SBOM, favorecendo a visualização e a contextualização de achados de segurança.
- Desenvolvimento e aprimoramento de dashboards, métricas, filtros e fluxos de análise de vulnerabilidades, incluindo controles de cotas de scans por aplicação e equipe, com foco na consistência das informações e na usabilidade operacional.
- Atuação na investigação e contextualização de vulnerabilidades e dependências com referências como OWASP Top 10, NIST NVD, MITRE CVE/CWE, CVSS e GitHub Advisory Database, considerando também o fim de suporte (EOL) de componentes.
- Participação, junto à equipe, no levantamento e desenvolvimento de controles RBAC, envolvendo perfis, permissões, segregação de acesso e proteção de operações e APIs para a plataforma.
- Apoio técnico e suporte ao ecossistema Sonatype, documentação e troubleshooting de ambientes corporativos, incluindo um cenário do setor financeiro para utilização de centenas de desenvolvedores. Além da participação em reuniões técnicas com os fornecedores, conduzidas em inglês. Hoje sendo a Xmart Solutions a empresa brasileira parceira da Sonatype com diversos profissionais especializados e capacitados para implementação e suporte do ecossistema Sonatype.
- Participação na parceria técnica entre Xygeni e Xmart Solutions, com acesso à plataforma, capacitação conduzida por especialistas e avaliação de recursos de AppSec e segurança da cadeia de software.
- Utilização do Semgrep, OWASP ZAP, Gitleaks e Dependabot em estudos e validações.
- Fluxo de trabalho aplicado a IA generativa e automações relacionadas a atividades de engenharia e segurança, integrando modelos, agentes e ferramentas por APIs e MCP para apoiar análises técnicas, documentação, QA e execuções controladas de fluxos, com atenção a permissão e proteção de dados, gerenciando toda governança de agentes e auditando decisões.

Estagiário de Desenvolvimento de Sistemas | dez/2025 – jun/2026

- Atuação em suporte técnico, ambientes Linux e Proxmox, observabilidade com Zabbix e Grafana e desenvolvimento web, além de responsabilidades relacionadas a Redes e Infraestrutura. Ampliação progressiva de responsabilidades até a efetivação.

FORMAÇÃO ACADÊMICA

UNICID | Tecnologia em Análise e Desenvolvimento de Sistemas | jun/2026 – dez/2027 (previsão)

SENAI | Técnico em Desenvolvimento de Sistemas | jul/2024 – jun/2026

PROZ | Técnico em Informática para Internet | jan/2023 – dez/2024

PROJETOS E INICIATIVAS SELECIONADAS

Sistema de QA (Quality Assurance) automatizado para validações de plataforma

Desenvolvimento de solução interna para apoiar testes pré e pós-release da plataforma, abrangendo validação de funcionalidades, integrações e permissões, com execuções controladas customizáveis, registro de evidências e rastreabilidade. Iniciativa voltada a reduzir a dependência de verificações exclusivamente manuais, economizando tempo e profissionais para as validações.

Benchmarking de ferramentas SAST

Elaboração e evolução de cenários controlados baseados em referências reconhecidas, como o OWASP Benchmark, para avaliar cobertura, precisão e ocorrência de falsos positivos e falsos negativos, apoiando a análise comparativa de ferramentas e a validação técnica de resultados de segurança.

Orquestração e auditoria de agentes e skills com IA

Exploração e desenvolvimento de fluxos com modelos comerciais e abertos, agentes, APIs e Model Context Protocol (MCP), voltados à automação de rotinas técnicas. Ênfase em governança, rastreabilidade, controle de acesso e uso responsável de modelos.

Open-Vaultin | AI Agent Harness Governance | open source

Projeto autoral, independente e open source, em aprimoramento contínuo (Early V1), voltado a Harness Engineering e governança de agentes de IA. Implementa agentes e skills, políticas, hooks do Codex, contexto persistente, registro de execuções e evidências, sincronização Git/MCP e roteamento consultivo com modelo decisor JEV/TypeSafe e fallback determinístico. O cliente mantém o loop principal; as garantias de execução dependem da integração. github.com/CarlossgLuz/Open-Vaultin

APIsec | laboratório autoral de segurança de APIs

Laboratório público em FastAPI para demonstrar BOLA, BFLA e BOPLA (OWASP API Security Top 10:2023), comparando comportamentos vulneráveis e protegidos em cenários isolados com dados fictícios. Inclui testes Pytest, Ruff, Bandit, Docker, CI pelo GitHub Actions e relatórios de evidências Markdown/JSON. Não executa scans de terceiros. github.com/CarlossgLuz/APIsec-LabTest

COMPETÊNCIAS TÉCNICAS

AppSec e DevSecOps: CI/CD, ASPM, SAST, SCA, DAST, Container Security, Secrets Scanning, SBOM, Secure SDLC, Secure Code Review, Vulnerability Management, EOL, Supply Chain Security e RBAC.

Análise de vulnerabilidades: OWASP Top 10, NIST NVD, MITRE CVE/CWE, CVSS, GitHub Advisory Database.

Ferramentas e integrações: XGuardian, Sonatype Guide, Nexus Repository, Nexus Lifecycle/IQ, Nexus Firewall, Xygeni, Semgrep, OWASP ZAP, Gitleaks, Dependabot, GitHub Actions e GitLab CI/CD.

IA e automação: LLMs comerciais e open source, Hugging Face, agentes, APIs, MCP, roteamento de modelos, engenharia de prompts, orquestração de fluxos e governança.

Desenvolvimento e operações: Python, JavaScript, TypeScript, React, Next.js, APIs REST, SQL, Git/GitHub, Linux, Docker, AWS, Azure, Proxmox, Zabbix, Grafana e Prometheus.

CERTIFICAÇÕES E IDIOMAS

Microsoft Azure Fundamentals (AZ-900) | fev/2026

Scrum Foundation Professional Certification (SFPC) | out/2024 – out/2027

Inglês: B2 (intermediário superior) | Uso em documentação e reuniões técnicas internacionais, em aperfeiçoamento com aulas particulares.